

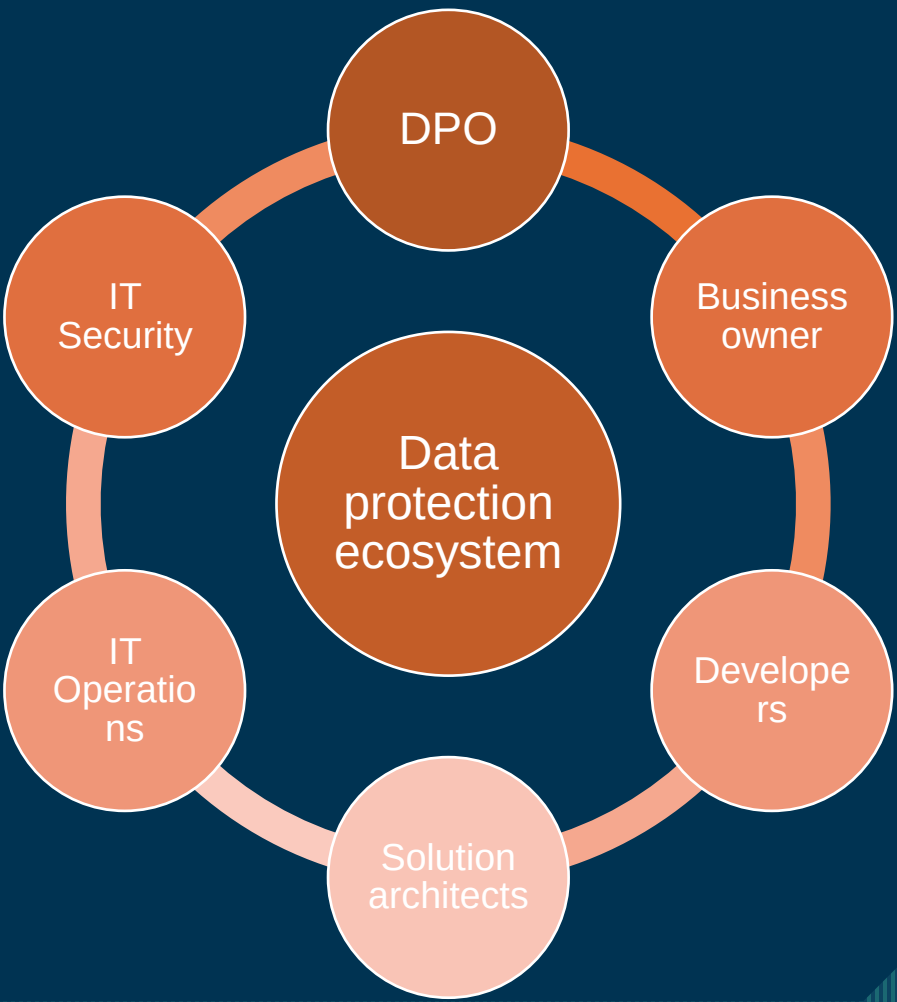
Overview

1. Privacy by design concept
2. Data oriented principles
 - A. Minimise/Separate/Abstract/Hide
 - B. Anonymisation and Pseudonymisation
3. Process oriented principles
 - A. Inform
 - B. Control
 - C. Implement
 - D. Demonstrate
4. Privacy by design in SDLC (Software Development Life Cycle)
 - A. Requirements
 - B. Design
 - C. Coding
 - D. Testing
 - E. Deployment
 - F. Maintenance / Change request
5. Additional resources

1 of 5 Privacy by design concept

Privacy by design – Including data protection (including IT security concepts) and integration with IT systems – entails technical, organisational and internal process adjustments, including CIA (confidentiality, integrity, availability).

Privacy engineering – A suite of design mechanisms and IT system integration with respect to data protection aspects, together with risk management concerning consequences on individuals.



Objective	Description
Predictability	Individuals, business owners and users being aware of the data processing
Management	Possibility to access, rectify or delete data
Unlinkability	Anonymisation/pseudonymisation of personal data when these are not needed

1 of 5 Privacy by design concept - usefulness

Integration of data protection specifics from the design phase (when the architecture of the IT system is created)

Ensure proper functioning of the IT system (user-centric approach)

Ensures integration with legacy IT systems

Avoids delays in deployment and changes to the initial architecture

Correlation with legal, technical and commercial requirements

1 of 5 Privacy by design - type of data processing

N o	Types of data processi ng	Applicable principles	Implementation
1	Collection	MINIMISE	Establish the data needed before collection. Delete unnecessary data. Ensure accuracy of data.
		AGGREGATE	Anonymisation at the local level (in the source IT system)
		HIDE	Lack of more correlation than necessary, encryption of data, identity masking
		INFORM	Providing information concerning the data processing to individuals
		CONTROL	Mechanism for granting/revoking consent
2	Analysis	AGGREGATE	Anonymisation
		HIDE	Anonymisation, using of only necessary data
3	Storing	HIDE	Encryption; authentication and rights management
		SEPARATE	Storing data in a distributed/decentralised manner, where possible
4	Use	AGGREGATE	Anonymisation; data quality measures
5	All types	IMPLEMENT/DEMON STRATE	Implementation of internal procedures, maintaining audit trails for proving compliance

2 of 5 Data oriented principles

Minimisation of data and limiting the possibility for identification of an individual:

Minimise	Limiting as much as possible the processing of personal data (only necessary processing) and anonymisation/pseudonomysation when possible.
Separate	Separating the data processing in tables/databases/IT systems/different networks.
Abstract	Limiting the granular processing of personal data
Hide	Hiding personal data in order to limit unauthorised access, including through access rights or interconnection with other IT systems

2.A of 5 Minimise/Separate/Abstract/Hide

- Using third party code/libraries – checking data collection/storing/processing
- **Token/session ID** – Limited/no personal data included; only encrypted/hashed data
- **Crash reports, telemetric data, metadata** – data minimisation for collection and aggregation analysis
- In an IT system chain (e.g. web server, middleware), each component to hold only necessary data
- Use of sensor data/location data only when actually necessary
- **Logs and metadata** – limited personal data, only if needed
- **Restricting access to data** – only individuals that need access and for the period they need it (internally and externally)
- Checking that third parties accessing personal data have proper agreements in place (DPAs)
- **Respecting data quality – synchronization with master IT systems**
- **Analyse the public data available in general to a potential attacker to identify an individual** - e.g. public data, google ID, device fingerprinting

2.A of 5 Minimise/Separate/Abstract/Hide

Collection minimisation

- Collecting only data needed at that moment, not collecting just in case it may be useful later on

Disclosure minimisation

- Limited disclosure of data internally or externally to only necessary situations

Replication/copying data minimisation

- Limiting the replication of data in multiple IT system (relevant also for keeping data accuracy) – e.g. temporary database for pre-processing data held on a web server

Centralising data minimisation

- Avoid a single point of failure

Minimising the possibility to correlate data

- Limiting the possibility of an attacker to correlate a significant number of data

Minimising retention period

- Identification of the minimum period necessary for keeping data (legal requirements, business need) before deleting them

2.A of 5 Minimise/Separate/Abstract/Hide

- **Saving data on the user device (permanent storage/cache)** – security analysis (encryption, secure access to storage area), deletion upon session termination
- **Multi-tenancy** – segregation and restriction of access among tenant (also in terms of logs, encryption keys held in vaults)
- **Not including personal data in communication** – e.g. email body, email title, names of files
- **Deletion of data temporary held in certain systems**
- **Visualisation of data/access through VPN to analyse data (e.g. for bugs)** – only if necessary and if there is a processing basis
- **Limitations due to legacy systems**
- **Examples of separation:**
 - Separation of data with higher level of confidentiality from lower level of confidentiality
 - Separation of data in database tables and limiting access to needed tables/attributes
 - Separation of access based on the zero-trust architecture (identity management, asset management, application authentication, network segmentation, and threat intelligence)

2.A of 5 EXERCISE - Minimise/Separate/Abstract/Hide

What would you analyse for the following to ensure minimise/separate/abstract/hide principle?

1. Use of external libraries for tracking of activity of users in a mobile application from which you receive an aggregation on various filters
2. Registration process that involves picture of ID and video call to compare images for identification of an individual

2.A of 5 Anonymisation and pseudonymisation

Anonymisation - unidentifiable

- Without unique identifiers in the IT ecosystem
- Without contact/identification data
- k-anonymity, l-diversity, differential privacy, etc
- No characteristics of the individual collected

Pseudonymisation – identifiable with reasonable efforts

- Without unique identifiers in the IT ecosystem
- Contact/identification data kept separately from the rest of the data
- Without common attributes between databases
- Collection of characteristics of individuals at a granular level

Pseudonymisation – identification with little effort

- Without unique identifiers in the IT ecosystem
- Contact/identification data kept separately from the rest of the data
- With common attributes between databases

Identified or identifiable

- Unique identifiers in the IT ecosystem
- Contact/identification data (CNP, ID card picture) kept in the same place as the other data

2.A of 5 EXERCISE - Anonymisation and pseudonymisation

- Anonymised data or pseudonymised data?
 1. Only banking transactions from a bank account (e.g. similar to bank excerpt information)
 2. Google analytics data held by Google for a single website

3 of 5 Process oriented principles

Information	Informing individuals on the data processing adequately from a content and timing perspective	• Description of data processing for IT systems • Bringing to the attention of individuals before commencing the data processing • Information about data protection incidents, if necessary according to legal requirements
Control	Individuals have control on the processing manner – especially consent and exercise of rights according to GDPR (access, restriction, deletion)	• Technical functionalities in the IT system or process management within the organisation • Performing the information steps before obtaining consent
Implementation	Adequate implementation of data protection requirements	• Access management • Implementation of specific measures resulting from the data protection analysis and from internal procedures • Ensuring implementation of requests by sub-contractors/co-contractors
Demonstrate	Ensuring the possibility to prove: - the measures implemented according to data protection legal requirements - The actions of individuals (e.g. users, clients) in terms of data protection	• Logging and audit trail

3.A of 5 Inform

- To identify if information notice should be followed by consent (if consent processing basis)
- Offer transparency and predictability to individuals
- No pre-ticking of tick boxes – need for actual action by the client to acknowledge information notice/to consent
- **The information notice should address:**
 - data collected from individuals
 - data obtained from third parties – e.g. vendors, marketing agencies, group companies
 - data sent to third parties – e.g. vendors, marketing agencies, group companies, authorities
- **Information notice should be:**
 - **brought to the attention of individuals prior to collection/processing of data**
example: registration form
 - accessible in the application and on the website:
Question: Why both?
 - clear, specific for the data processing relating to the IT system and subsequent data processing in the IT ecosystem of the organisation

3.A of 5 EXERCISE - Inform

How would you bring to the attention of individuals the information notice in the below cases?

1. Personal data obtained from a customer research agency in relation to customer views on your organisation's product
2. A new feature of the mobile app (added in the new release and updated automatically in the mobile phones of individuals) requires the use of location and other sensors in order to function properly

3.B of 5 Control

- **The user should be able to configure certain elements concerning personal data – e.g. cookies, tracking actions, granting/revoking consent**
- **Master IT system to be set for ensuring the accuracy of personal data**
- **Sending the user preferences to all third parties involved in the process if they have different IT systems than the organization ones**
- **Propagation of changed user preferences throughout all systems**

3.B of 5 EXERCISE - Control

How would you design the IT system in the following scenarios to address control of individuals on their data?

1. A mobile app for notification about sales in the user's favourite online stores – user wants to stop receiving notifications about specific stores
2. Google analytics cookies on a website

3.C of 5 Implementation

Processing basis specifics

- **APIs** – Identify legal basis for connecting – creation in a modular manner in order to reflect need to know principle (same for any reports)
- Collecting data/ Disclosing data – interconnection with IT systems (internal or external)

Accuracy of data

- **Validating use input** – specific business requirements/technical requirements
- **Integrity of data** – being able to prove that such data was introduced by the client himself/herself (audit trail)
- If data replicated in multiple IT systems (internal or external) – instant synchronization mechanism (exception – DWH, Data lakes); identify master IT system
- **Deletion of data no longer accurate (from back-ups, replications, middleware)**

3.C of 5 Implementation

CIA specifics

- Sending personal data via email vs sending links to clients in email
- Including in the code/architecture triggers in case of data breach – integration with SIEM solution
- **Use of video/audio/location/sensors** – stop when timeout
- **Timeout** in case of inactivity
- **Data at rest and data in transit – proper encryption/protection mechanisms**

3.C of 5 Implementation

Disclosure of data to the organisation

- Transfer from a vendor, IT maintenance company, for proof of concept, for sector research
- Transfer from group companies
- Transfer from authorities

- Identification of processing basis (having an agreement in place does not mean that any data can be transferred for any purpose)
- **Adequate information notice to individuals**
- **Identification of any other requirements**
- Location of data stored/location of accessing data (for the entire supply chain)

Disclosure of data by the organisation

- Transfer to a vendor, IT maintenance company, for proof of concept, for sector research
- Transfer to group companies
- Transfer to authorities

3.C of 5 EXERCISE - Implementation

How would you approach data accuracy in the following situations?

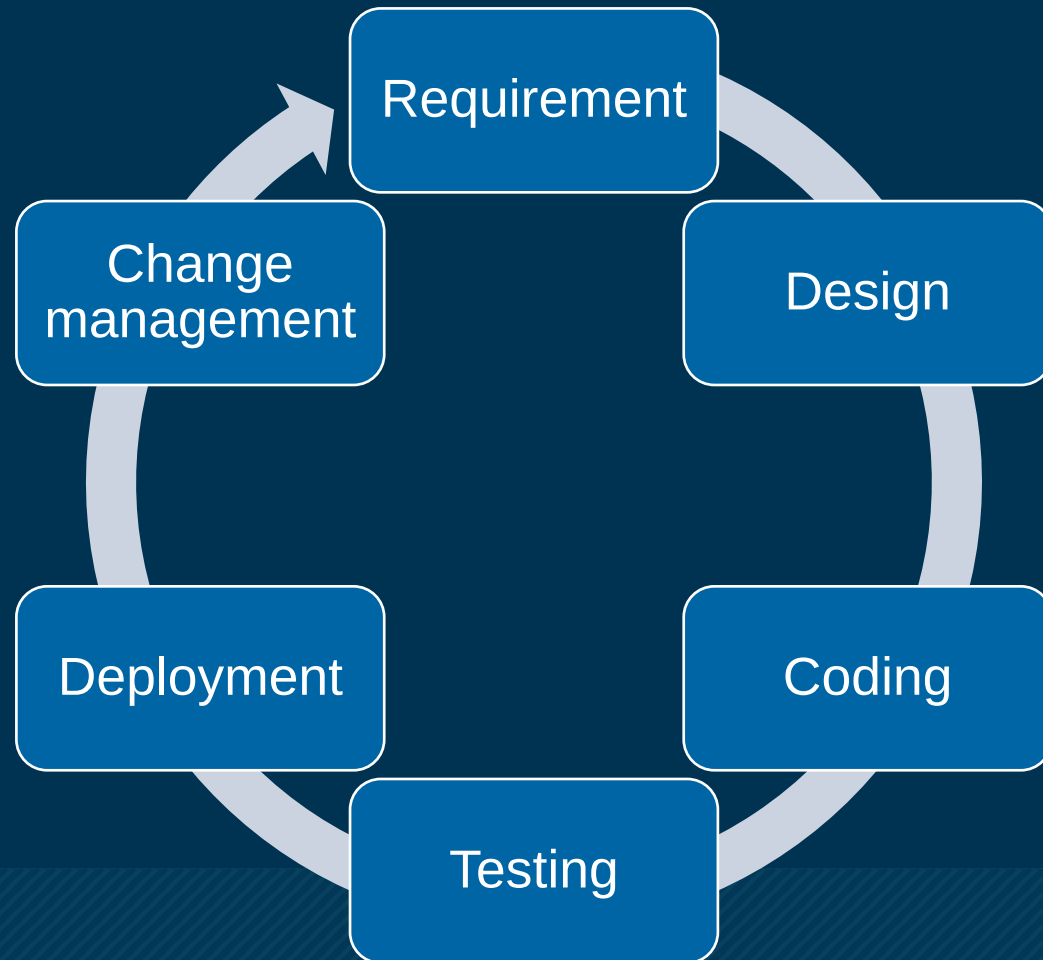
1. New user registered with first and last name, email address and telephone number
2. Email address in the core database about users can be updated from multiple sources:
 - From mobile app by users
 - From web application by users
 - By employees through their employee interface when a client calls the call center

3.D of 5 Demonstrate

Documentation

- For actions of the user that produce legal effects in terms of data protection
- **Proper time stamping**
- **Data protection analysis – DPIA/balancing tests**
- Proper documentation in the registry of processing activities

4 of 5 Privacy by design in SDLC



4 of 5 Privacy analysis life cycle

Requirement

Difficult to define at the outset; risk appetite

Offering of guidance

Templates for specific data processing

Design

Legacy and group systems

Correlation with existing systems

Define requirements for initial design

Coding

Static code analysis

Third party source code

Third party libraries

Testing

UX vs privacy

Privacy testing

White box testing

Deployment

Implementation steps

Regular reviews

Audits

Change management

Identification of impact on personal data

Triggers for privacy analysis

Restarting the SDLC

4 of 5 Privacy by design in SDLC

Specifics depending on development methodology

Waterfall

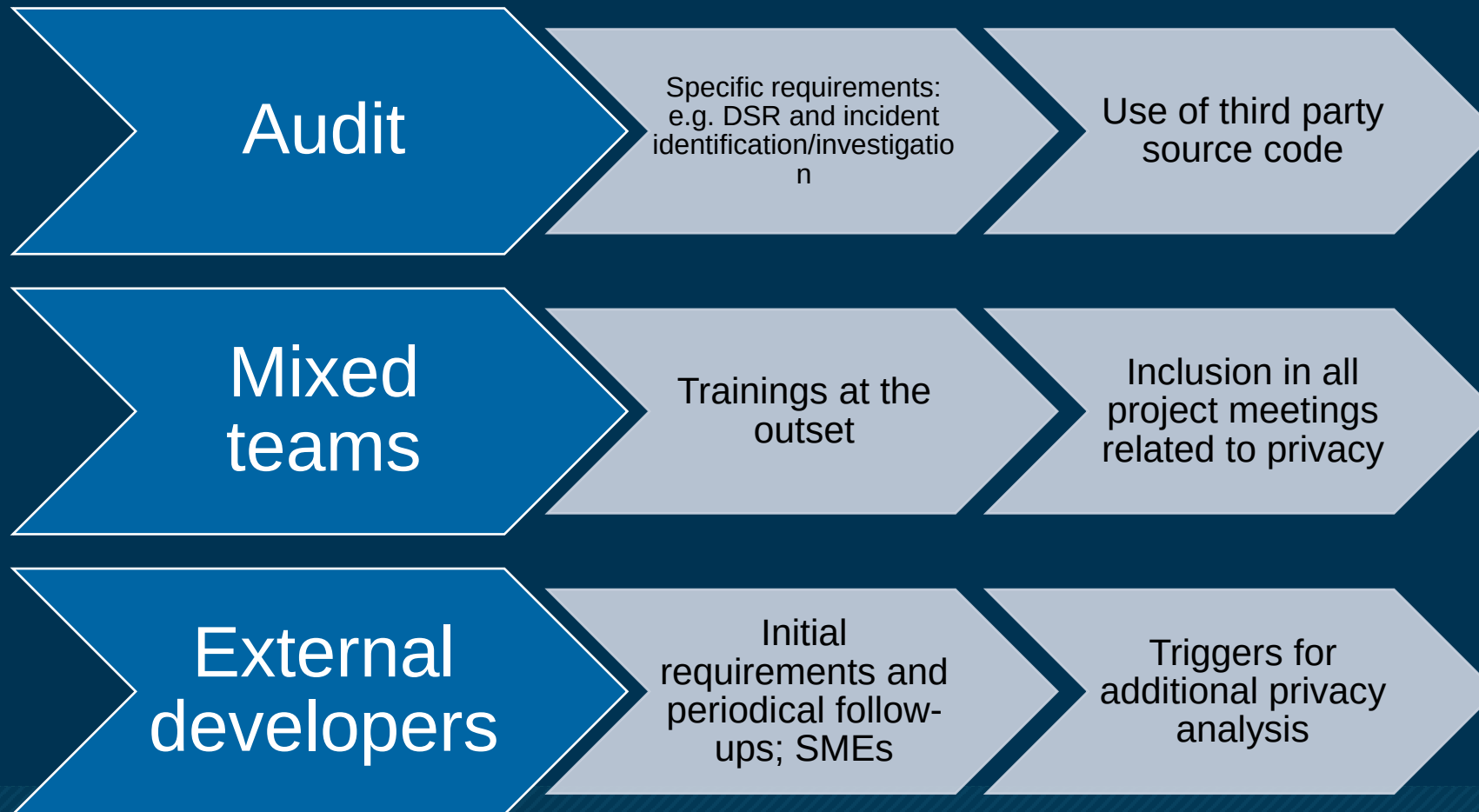
- **Outset of project** – the general requirements are detailed
- **End of project** – formal assessment of project is performed

Agile/Scrum

- **Each sprint** – for each change business, privacy and developers discuss privacy implications
- **Each meeting** – real-time awareness of changes to architecture

4 of 5 Privacy by design in SDLC

Use of third parties



4 of 5 Privacy by design in SDLC - Data life cycle

	Collection from an individual	Collection from other entities	Storing	Processing for the initial purpose	Processing for a subsequent process	Disclosure of data to other entities (e.g. vendors) for the initial collection purpose	Transfer of data as per legal obligations – e.g. to authorities	Deletion of data
Inform – data transparency	X	X	To include upon collection	Identified upon collection	To be included when collecting/when establishing subsequent purpose	To be included upon collection	To be included upon collection	To be included upon collection
Identification of the specific data processing purpose	X	X	Identified upon collection	Identified upon collection	X	Identified upon collection	Identified upon collection	-
Data minimisation	X	X	-	X	X	X	X	X
Identification of adequate processing basis	X	X	Identified upon collection	Identified upon collection	X	Identified upon collection	Identified upon collection	-
Need to know principle (access management)	X	X	X	X	X	X	X	X
Data accuracy	X	X	-	X	X	X	X	-
Establishing retention period and deletion mechanism	X	X	X	X	X	X	X	-
Technical and organisational security measures (CIA)	X	X	X	X	X	X	X	X

4 of 5 Privacy by design in SDLC - matrix

	Minimise/Separate/Abstract/Hide	Anonymise/Pseudonymisation	Inform	Control	Implement	Demonstrate
Requirements	X	X	X	X	X	-
Design	X	X	X	X	X	X
Coding	X	X	X	X	X	X
Testing	X	X	X	X	X	-
Deployment	X	X	-	-	X	-
Maintenance/Change requests	X	X	X	X	X	X

4.A of 5 Requirements

- **Identify from the outset** the personal data aspects that have to be integrated with the business requirements
- Off-the-shelf with customisation – from the request for proposal phase

4.B of 5 Design

- **Proactiv, not reactive** – identify the processing activities from the outset of the design phase – data protection requirements may require changes to the IT solution/architecture
- Involve the data protection team/DPO
- Requirements differ on the types of IT system – client facing, employee users only, backend, middleware, microservices, API
- API – analysis at creation and at usage
- Including incident identification/response in the design
- Including data subject request handling/retention period in the design
- Data protection process/controls/measures to be included in the UML, IT architecture, UX/UI parts

4.C of 5 Coding

- Proper handling of exceptions – in order to prevent unauthorised data disclosure
- Have in mind the data processing activities and correlation with other IT systems when coding
- Analysis of third party libraries/third party code
- If new features/processing activities added, re-evaluation

4.D of 5 Testing

- Preparing testing early – identify the use cases needed for testing – to create synthetic data/anonymised data
- Limited exemption when testing with real/production data – properly analysed before using and properly documented/monitored
- Specific access for testing environment based on need to test and limited in time

4.E of 5 Deployment in production

- Ensuring that the environment to which the deployment is made is identical in terms of configurations/data processing/data transfer to the testing/development environment
- Important moment for implementing access management/segregation of duties properly

4.F of 5 Maintenance/Change Management

- To be analysed for any initiative to change a data processing activity (which includes changing the features/structure of an IT system)
- **Examples:**
 - New interconnection of an IT system to send data to another IT system
 - New module with new features added to the IT system
 - The IT system front-end is changed to include tracking of users

4.F of 5 EXERCISE - Maintenance/Change Management

What is the most efficient control to ensure privacy by design analysis in case of changes to an IT system?

- A. Mandatory approval to be obtained from the data protection department before entering into production of the new version of the IT system
- B. Mandatory involved of the data protection department when the change is being designed
- C. Notification sent to the data protection department when the change is approved

5 of 5 Further reading

- OASIS – Privacy by Design Documentation for Software Engineers (<http://docs.oasis-open.org/pbd-se/pbd-se/v1.0/pbd-se-v1.0.html>)
- OASIS – Annex Guide to Privacy by Design Documentation for Software Engineers (<http://docs.oasis-open.org/pbd-se/pbd-se-annex/v1.0/pbd-se-annex-v1.0.html>)
- MITRE – Privacy engineering (<https://www.mitre.org/publications/technical-papers/mitre%E2%80%99s-privacy-engineering-tools-and-their-use-in-a-privacy>)
- ENISA – Privacy by design si privacy by default (<https://www.enisa.europa.eu/publications/privacy-and-data-protection-by-design>)
- Spain DPA – Guidance privacy by design and default (https://www.aepd.es/sites/default/files/2019-12/guia-privacidad-desde-diseno_en.pdf)
- LIND(D)UN – privacy threat modelling (<https://www.linddun.org/downloads>)
- Norwegian data protection authority – privacy by design guidelines (<https://www.datatilsynet.no/en/about-privacy/virksomhetenes-plikter/innebygd-personvern/data-protection-by-design-and-by-default/>)
- National Institute of Standards and Technology (NIST) – NISTIR 8062 An Introduction to Privacy Engineering and Risk Management in Federal Systems, Jan 2017 (<https://nvlpubs.nist.gov/nistpubs/ir/2017/NIST.IR.8062.pdf>)
- ISO 27550:2019 – Information technology — Security techniques — Privacy engineering for system life cycle processes
- ISO 29100:2011 – Information technology — Security techniques — Privacy framework



Questions?

Email: larisagabudeanu@gmail.com